XDef 2017

对话·交流·合作　　前沿·实用·人才

报告题目：基于静态分析和规则匹配的Android应用漏洞检测系统

学生代表：王晓森

指导老师：李瑞轩

所在学校：华中科技大学

所获奖项：2017年全国大学生信息安全竞赛一等奖

邮箱：wxs_student@163.com

QQ：1139983936

微信二维码见右侧

提纲

1.平台开发背景

2.系统调度

3.APK逆向分析

4.程序逻辑分析

5.漏洞库规则匹配

6.测试结果

7.IDC实验室简介

平台开发背景

平台开发背景

Android在随着移动互联网产业的飞速发展 移动智能终端在全球范围内热销，全球智能手机市场的份额占到85%。

1 Android应用开发绝大多数都是小型创业公司和独立开发者，往往**缺少大型软件公司常备的代码审计和代码安全规范检查**，使得Android应用软件的安全漏洞尤为严重。

2 在大量安全事件中,**APP的安全漏洞被黑客作为攻击入口,**通过侵入APP获取用户隐私以及企业数据库存储的数据,损坏用户和企业的利益,影响恶劣。

平台开发背景

2016年,仅以乌云漏洞平台曝光的安全漏洞为例, **超过10家知名APP被曝存在安全漏洞可导致超1000万用户隐私泄露**,这些安全漏洞的种类不一,漏洞的利用攻击手法也不同,但是攻击的最终指向目标都是用户隐私及企业数据。

触目惊心的安全现状,**超9成APP含有安全漏洞。**

3

目前**市场上的Android应用漏洞检测平台检测出的漏洞类型不明确**，且有些平台**检测出的漏洞过于单一**，不能帮助开发者准确分析漏洞产生的原因，大多数平台同样不能准确定位漏洞产生的位置。

因此，我们针对独立开发者，**研究并实现Android应用漏洞检测系统，并将准确的漏洞信息和修复建议反馈给用户。**

系统调度

系统调度

装载配置文件

配置数据库信息
加载开源框架平台的路径

1

2

构造多线程池

具体实现apk分析过程中的线程调度

系统持续监测

将未完成的分析任务添加到任务队列，一个apk分析任务实例化为一个线程

3

4

对apk进行逆向工程

调用函数analysis.run()，将应用的apk文件反编译成非常接近打包前的原始格式，包括可以读取的Manifest文件和smali代码

分析检测Manifest文件和Smali代码

调用Manifestchecker和Smailchecker函数进行相关分析

5

6

静态数据流分析

调用函数InfoflowAnalysis，通过soot开源框架进行数据流分析

规则匹配

通过程序逻辑分析的结果与对应漏洞规则库进行匹配

7

系统持续监测中……

APK逆向分析

APK逆向分析

APK文件反编译

准备

文件类型
是否可读
文件备份

反编译

解压缩apk文件
反编译dex文件

漏洞分析

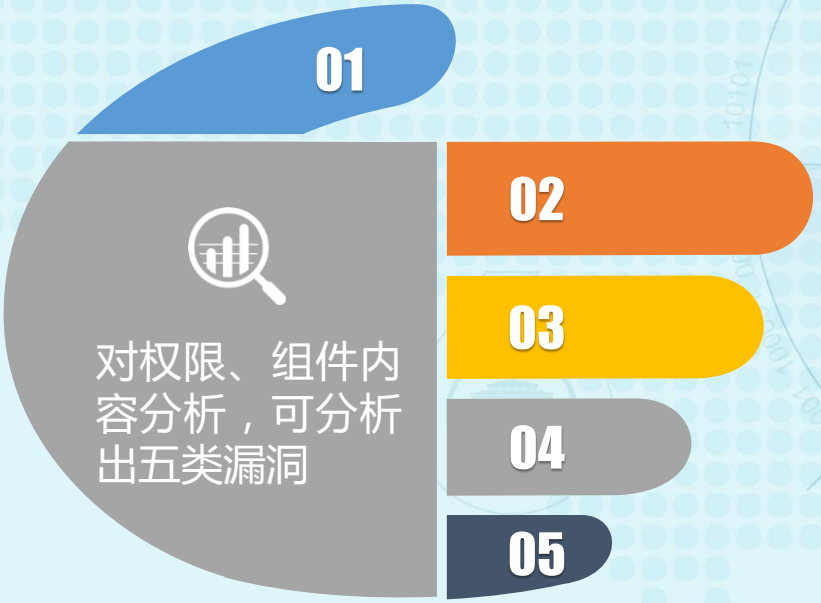
分别对Manifest文件
和Smali代码进行规则
匹配，进而分析其漏洞

APK文件反编译分析整体流程

APK逆向分析

Manifest文件分析

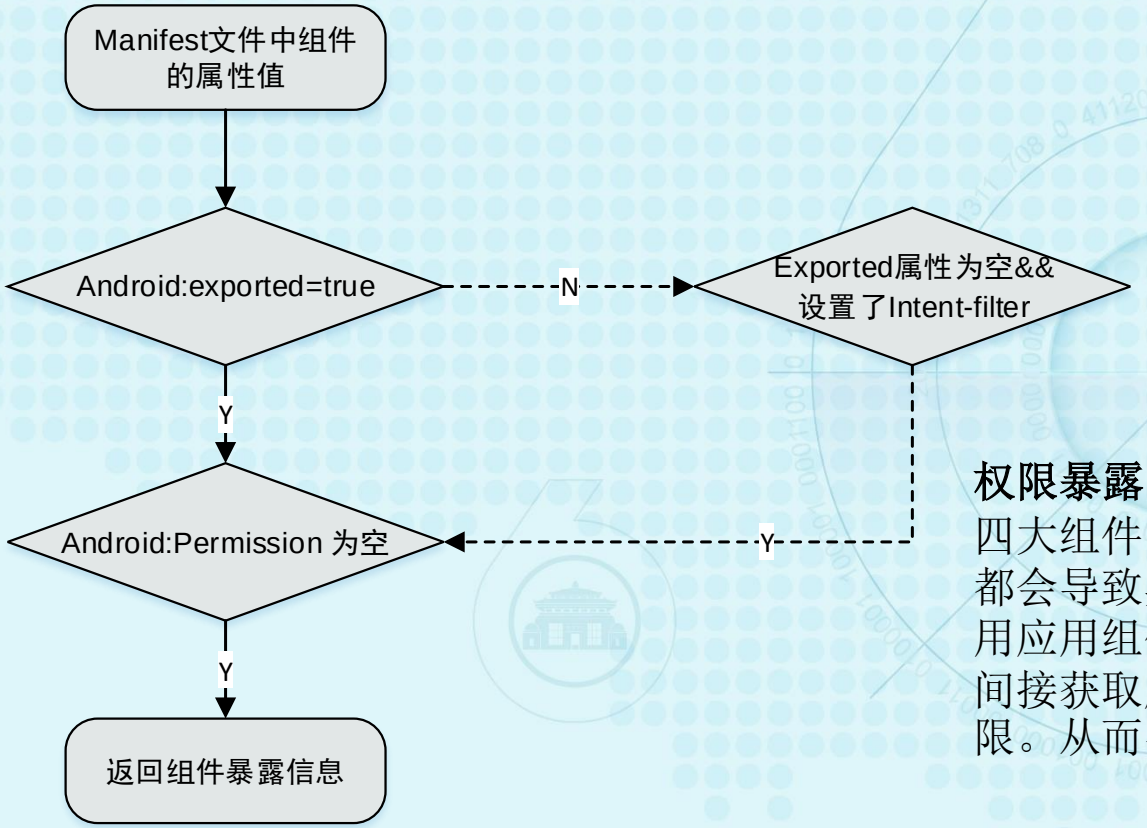
Manifest文件作为应用的清单，包含着应用的权限申请信息、组件注册信息、配置信息、版本信息等丰富的内容。其中，与应用安全相关的主要包括应用申请的**权限**、**组件**等内容。



- Activity暴露漏洞
- Service暴露漏洞
- Broadcast Receiver暴露漏洞
- Content Provider暴露漏洞
- 权限暴露漏洞

APK逆向分析

组件暴露分析



权限暴露

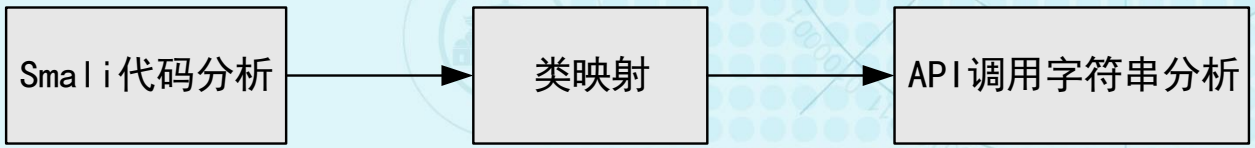
四大组件中任一组件暴露，都会导致其他应用可以调用应用组件完成相应操作，间接获取应用所申请的权限。从而导致权限泄露。

APK逆向分析

smali代码分析

针对smali代码的分析主要是扫描smali代码，通过关键词匹配的方式得到其类名、方法名等信息，并构造SmaliClass类对这些信息进行存储，以备后面使用。

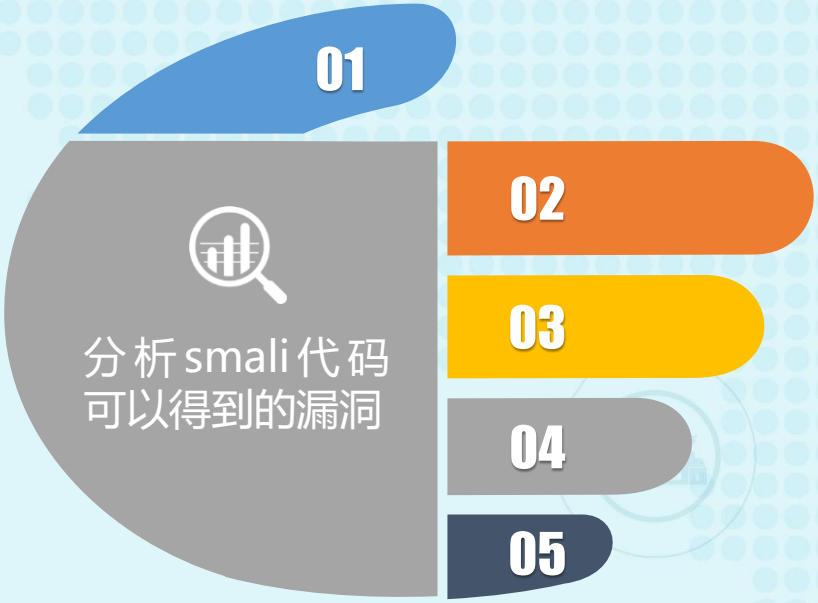
该部分主要是从SmailiClass类获取并分析一些与应用安全相关的关键API函数的调用信息，根据API与权限的映射关系，分析应用实际使用的权限等，为检测相应的安全漏洞的提供元数据。



APK逆向分析

smali代码分析

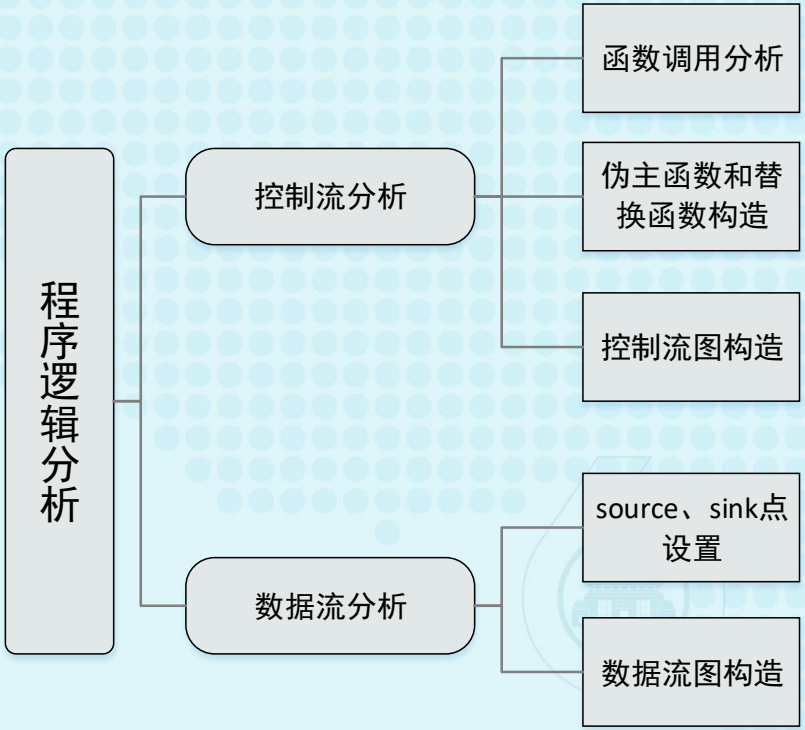
采用漏洞匹配的方式，我们可以在程序中分析出如下五种漏洞：



- WebView远程代码执行漏洞
- SHELL命令执行漏洞
- Package资源共享漏洞
- 弱密码漏洞
- 过多权限申请漏洞

程序逻辑分析

程序逻辑分析



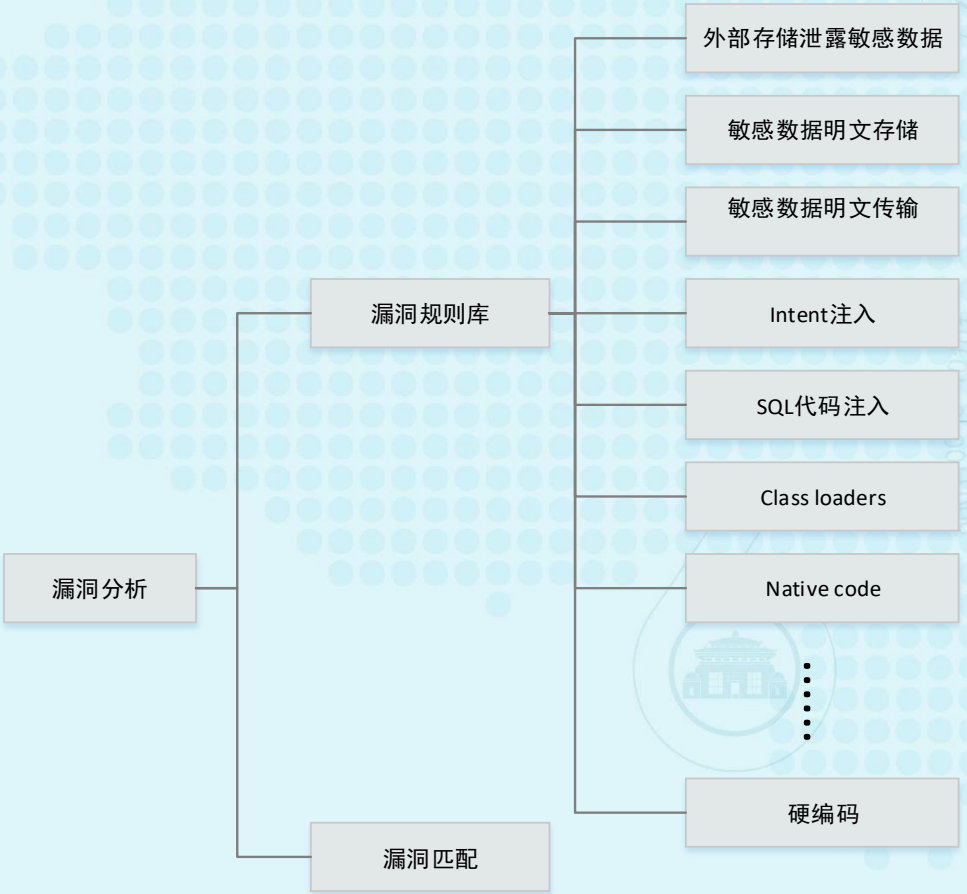
程序逻辑分析
主要分为**控制流分析**和**数据流分析**，在开源框架flowdroid拓展实现

控制流分析：
分析应用的Manifest文件、Layout布局文件和.dex文件
生成应用的伪主函数，构造控制流图

数据流分析：
设置source点和sink点，对生成的控制流图进行检测，采用污点分析对控制流图进行遍历，得到污点数据的传播信息

漏洞库规则匹配

漏洞库规则匹配



- 构建漏洞规则库
  建立漏洞匹配规则checker
- 主要是读取程序逻辑分析获得的对应方法名以及source和sink的相关信息，进行source和sink点匹配，判断是否与漏洞规则库的规则相匹配。

测试结果

测试结果

Web 站点及自动化遍历

1

基于静态分析和规则匹配的Android应用漏洞检测系统

2

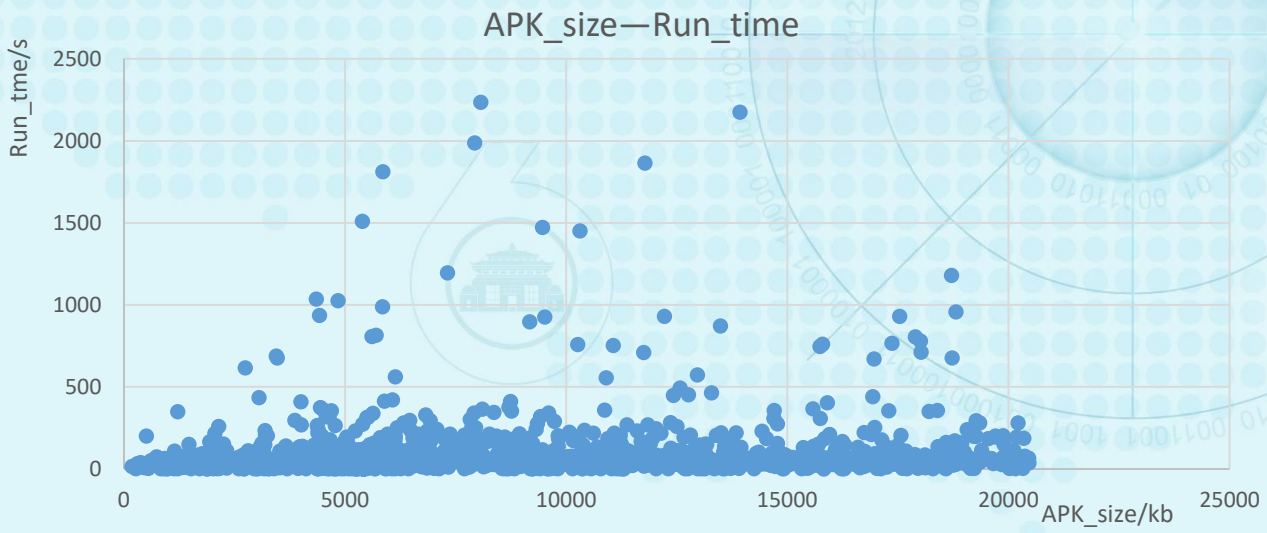
我们在服务器上实现自动化遍历，对于从应用市场上爬虫得到的大量apk进行分析检测，以测试平台的健壮性和抗压性。

APKname	MD5	ConsumeTime	StartTime	ApkSize(KB)	ActivityExp	ServiceE	ReceverE
26F881EEI	26F881EEI	1m 1s	7/24/2017 22:47	17348	0	0	0
71A98492	71A98492	0m 11s	7/24/2017 22:48	17157	0	0	1
3518E9B8	3518E9B8	0m 34s	7/24/2017 22:48	9521	0	0	1
DFD7ACBFI	DFD7ACBFI	0m 11s	7/24/2017 22:49	3291	0	0	0
F13521C2	F13521C2	0m 40s	7/24/2017 22:49	17502	0	0	0
AFBB3545	AFBB3545	0m 53s	7/24/2017 22:50	10030	1	0	1
7602AE0B	7602AE0B	2m 26s	7/24/2017 22:51	10388	0	0	0

测试结果

对在应用市场上爬虫得到的1512个apk放在我们的平台上进行检测

	分析成功	Manifest文件分析	Smail字节码分析	静态数据流分析	安全apk
所占比例	92.59%	66.98%	93.78%	81.77%	4.14%
检测个数	1399	937	1312	1144	58



IDC实验室简介

华中科技大学
智能与分布计算实验室
（IDC-Lab）

7 固定研究人员:

- 2 教授
- 2 副教授
- 1 讲师
- 2 博士后

41博士和硕士研究生

華中科技大學智能与分布计算实验室
Intelligent and Distributed Computing Laboratory

IDC-Lab

图片新闻

MORE

辜希武老师与博士生段东圣... 1 2 3 4

最新动态

MORE

- 李瑞轩教授申请的百度主题研究项目获得资助 NEW 03-18
- 段东圣同学的论文被顶级期刊IEEE TKDE录用 12-30
- 文坤梅副教授申请的国家自然科学基金获得资... 09-10
- 叶威博士赴墨尔本参加TrustCom 2013国际会议... 07-26
- 李瑞轩教授赴荷兰阿姆斯特丹参加ACM SACMAT... 06-26
- 段东圣同学荣获教育部博士研究生学术新人奖 01-18
- Khaled M. Banafaa同学论文被DASFAA 2013录... 12-30
- 段东圣同学赴比利时参加ICDM 2012国际会议 12-10
- 段东圣同学的论文被ICDM 2012录用 09-21
- 康万胜同学的论文被ICPADS 2012录用 08-29
- 实验室承办的2012龙星计划课程取得圆满成功 08-10

成果展示

- 密文全文检索系统(Mimir)
- 安全搜索引擎(SeSeek)
- 多域访问控制系统(MDAC)
- 统一权限管理平台(UPA)
- 安全标签库系统(SecTag)
- 学术会议检索系统(iCon)
- 学术语义搜索系统(SmartCH)
- 异构数据集成系统(Panorama)

IDC实验室简介

华中科技大学智能与分布计算（IDC）实验室成立于1983年，其前身是华中科技大学计算机系软件工程与系统集成研究室，实验室主任李瑞轩教授，原华中科技大学计算机学院院长卢正鼎教授任实验室名誉主任IDC实验室隶属于华中科技大学计算机科学与技术学院并行分布式计算研究所，拥有实力雄厚的师资力量、充满活力的科研梯队。现有教授2名、副教授2名、讲师1

通知公告

MORE

- 澳大利亚墨尔本大学张瑞副教授学术讲座通知 NEW 04-18
- 移动互联产业发展的机遇与挑战特别论坛通知 NEW 04-08
- IDC实验室2014年春季羽毛球双打友谊赛通知 NEW 03-03
- IDC实验室2013年秋森林公园徒步游活动通知 11-28
- 澳大利亚墨尔本大学张瑞高级讲师学术讲座通... 10-29
- 美国堪萨斯大学浣军副教授学术讲座通知 07-10

友情链接

- GPC 2012
- 龙星计划课程
- 计算机学院
- 华中科技大学
- 武汉光电国家实验室（筹）
- 服务计算技术与系统实验室

实验室主任简介

李瑞轩

华中科技大学　教授、博导
华中科技大学　并行分布式计算研究所副所长
华中科技大学　智能与分布计算实验室主任
加拿大多伦多大学　博士后
加拿大康考迪亚大学　兼职教授
澳大利亚西悉尼大学　兼职高级研究员

- 近年在ACM CCS、ACM SACMAT、USENIX LISA、ICDM、ICPP、IEEE TKDE、TCC等国际顶尖杂志和会议论文100多篇
- 获授权发明专利15项，软件著作权7项，获湖北省优秀博士学位论文奖
- 作为项目负责人主持4项国家自然科学基金、1项国家863计划、1项电子信息产业发展基金、2项国家密码发展基金、1项湖北省自然科学基金、1项湖北省软件专项基金等科研项目20余项。

研究成果

- 发表论文
  - Over 300 publications
  - IEEE TKDE, IEICE Trans, Comp J, Info Sci, JPDC, JNCA, FGCS, Comp Comm, CSSE
  - ACM CCS, ACM SACMAT, USENIX LISA, ACM MM, ICDM, ICPP, CIKM, ICTAI, ISC, DEXA, SCC
  - Science in China, JCST
- 发明专利
  - 18 patents (15 Authorized)
- 计算机软件著作权
  - 15 software copyrights

主要研究方向

- 大数据管理与分析
  - 信息检索
  - 数据挖掘
  - 社会网络分析
- 分布式系统安全
  - 云计算与云存储安全
  - 移动互联网安全

Addr.：武汉市珞喻路1037号华中科技大学南一楼442

Tel: 86-27-87544285　Fax: 86-27-87545004

Email: rxli@hust.edu.cn

Web：http://idc.hust.edu.cn

THANKS
感谢关注